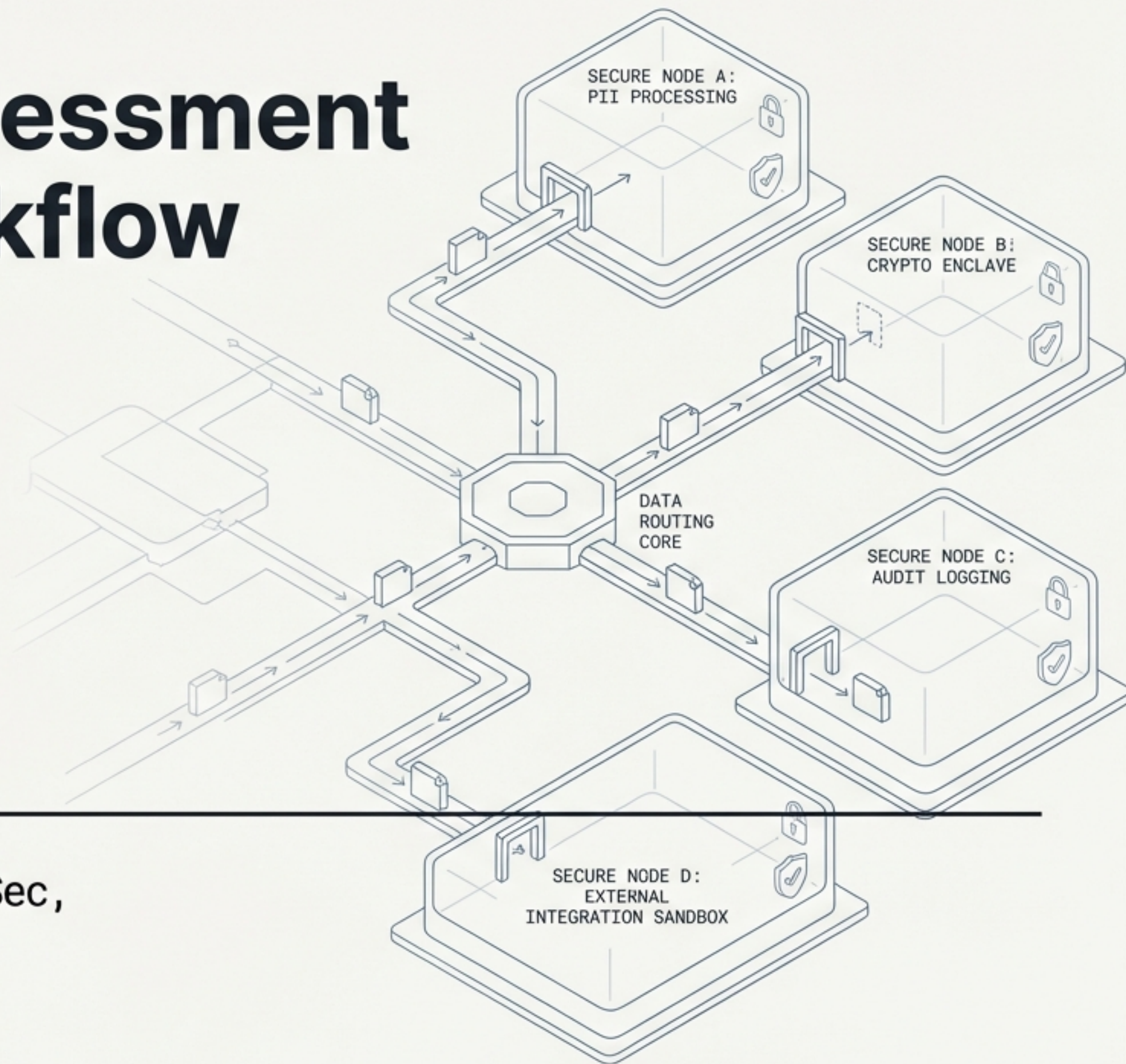


n8n Platform Assessment & Encrypted Workflow Architecture

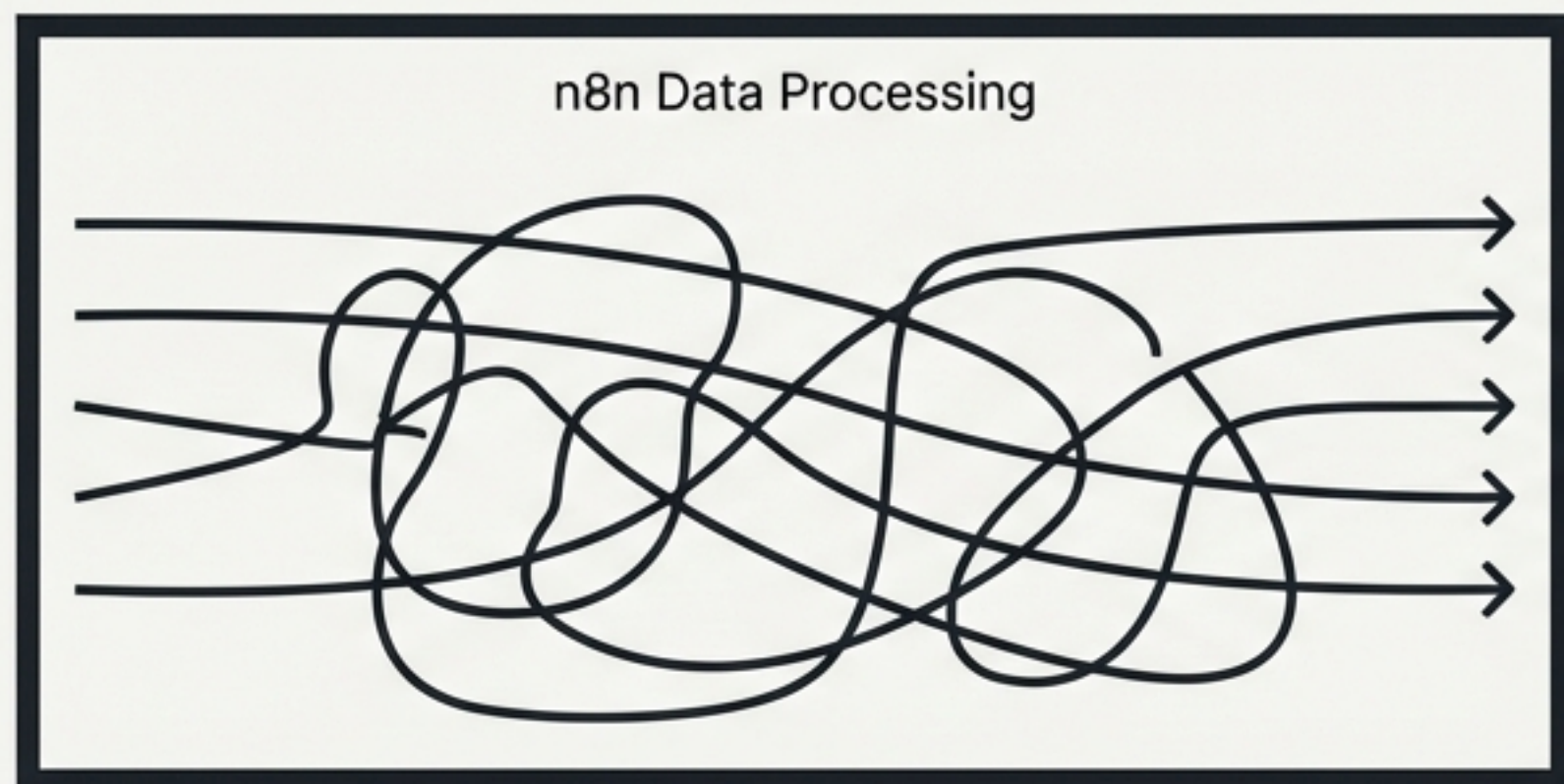
Architectural Decision Briefing
Version 0.7.4
27 Feb 2026

Primary Audience: Architecture, AppSec,
DevOps, and Development Teams

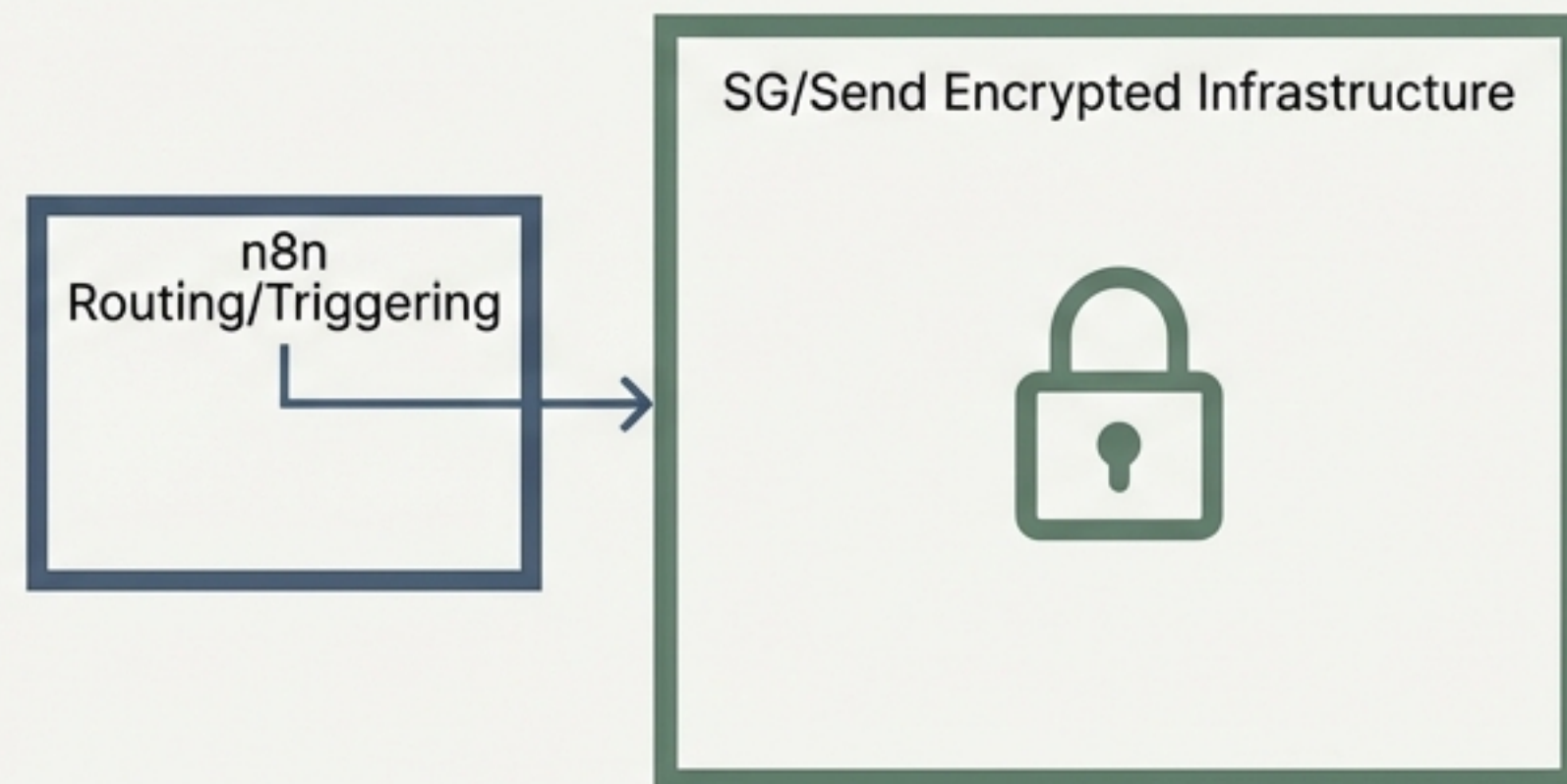


Contain n8n and implement zero-knowledge logging

Before



After



The Directive

Do not replace n8n. Contain it to routing and triggering functions.

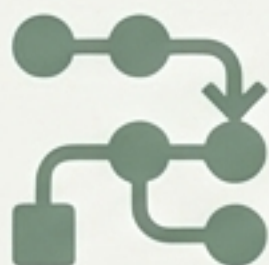
The Threat

n8n's execution logs currently expose sensitive plaintext data and decryption keys, violating our zero-customer-data-on-server-leak principle.

The Resolution

Pivot from plaintext orchestration to an Encrypted Envelope architecture. All sensitive data handling moves to isolated Lambda infrastructure.

n8n excels as a visual routing and orchestration layer



Visual flow builder

The block-connection model is genuinely good for seeing workflow structure at a glance.



Debuggability

Execution logs show exactly what happened at each step, which is invaluable for troubleshooting.



MCP integration

Connecting to SG/Send and other services via the Model Context Protocol (MCP) works cleanly.



Trigger ecosystem

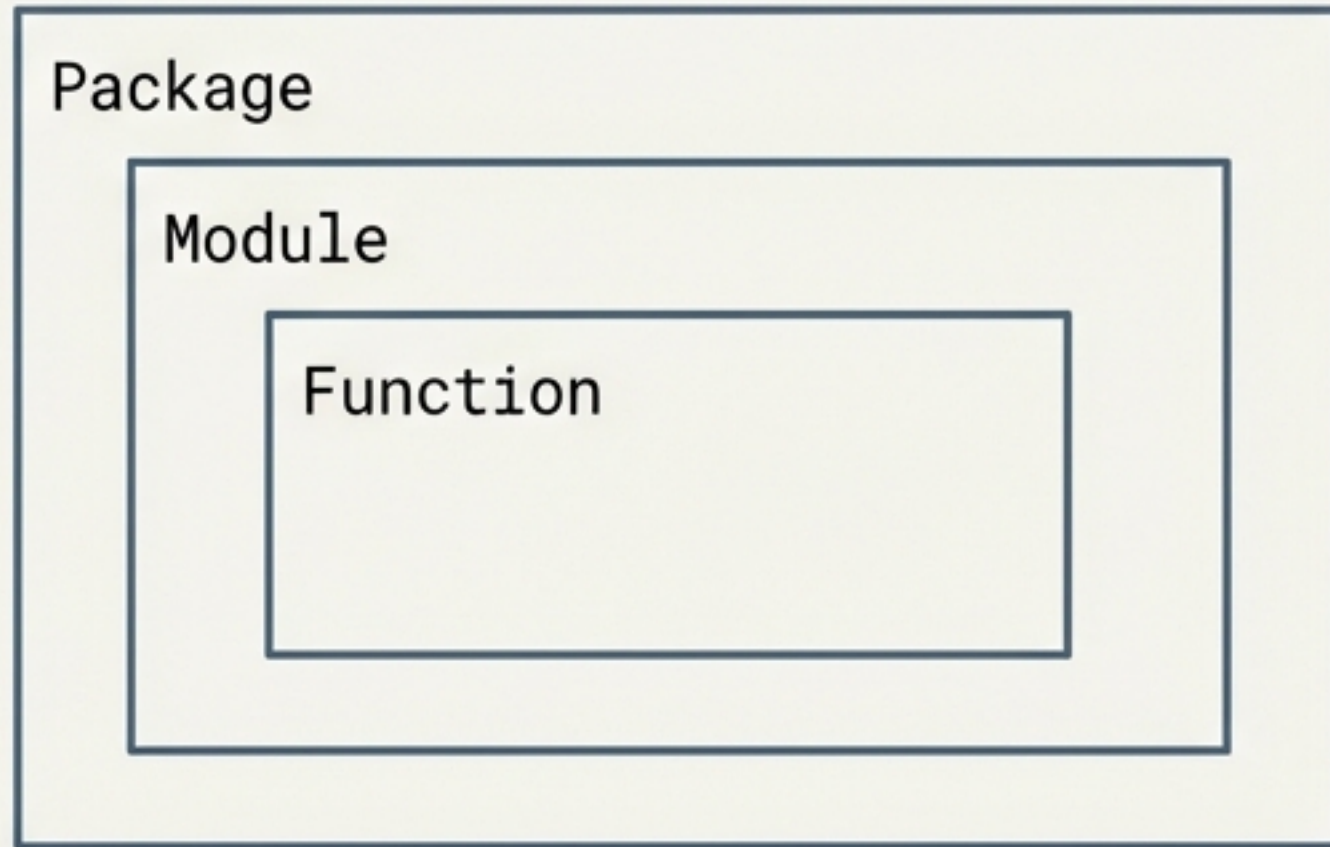
Broad coverage for event sources, including webhooks, schedules, and email triggers.

Operational complexities compound rapidly at scale

Critical Risk	No secrets management. API keys and credentials are stored in node configurations, visible in JSON and execution logs.
High Risk	No real version control. Workflows use snapshot backups instead of diffs, branching, or merging.
High Risk	Brittle XML/JSON transformations. Hard-coded field references break silently when upstream names change.
High Risk	Complexity scales badly. No refactoring tools or clean sub-workflow composition.
Medium Risk	Poor editing environment. No undo function for deleted nodes or connections.

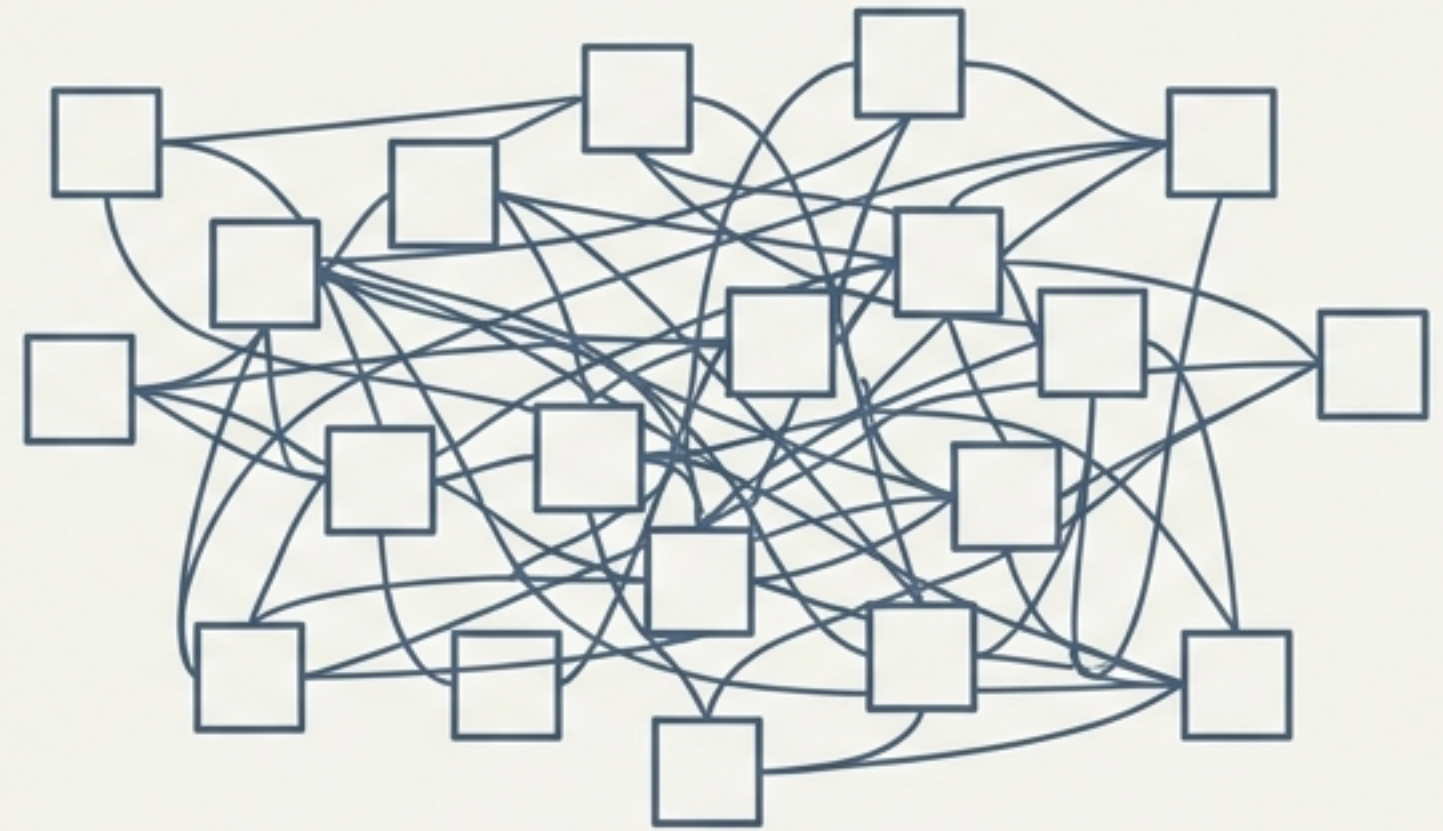
Visual programming lacks the abstraction mechanisms required for scale

Traditional Code



Traditional code manages complexity through abstraction (extracting functions/modules).

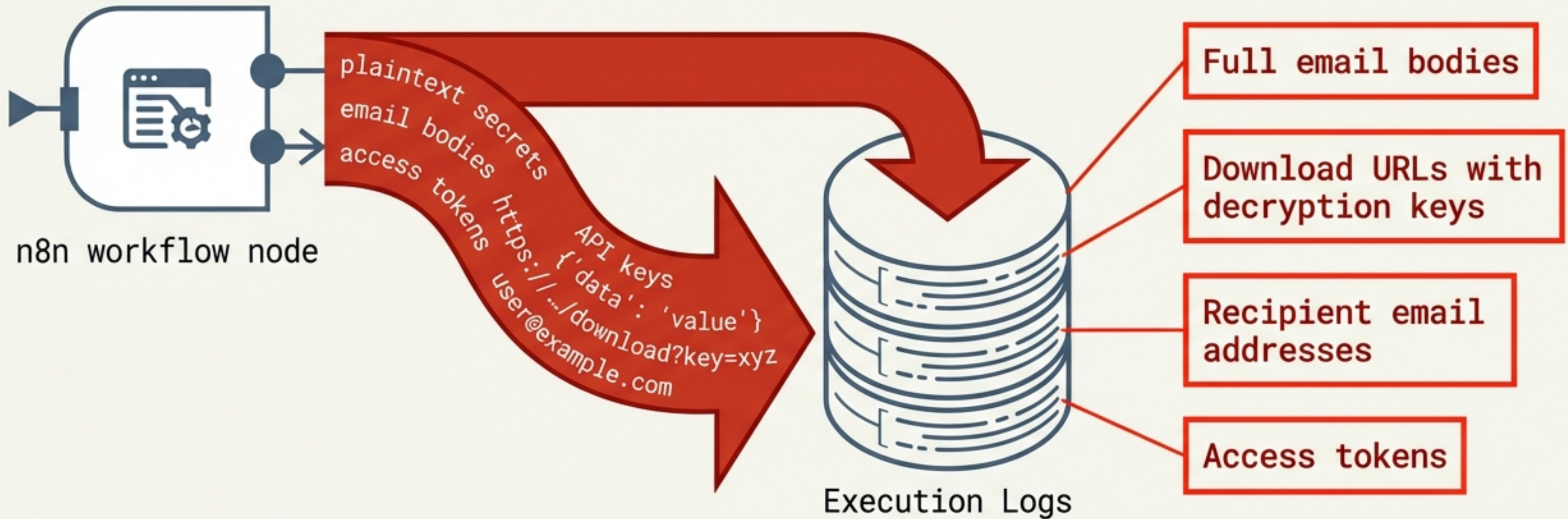
n8n Visual Flow



In n8n, workflows that start simple become unmanageable because every detail remains visible.

Key Assessment Note: Faster to code than to build visually at scale. Coded versions are inherently less brittle, more testable, and more version-controllable.

The default execution logs represent a critical data leak surface



- n8n captures full request and response bodies for every node by default.
- A full n8n compromise (database or log access) exposes all of this information.
- This is a direct violation of the zero-customer-data-on-server-leak principle.

Isolating acceptable metadata from sensitive customer data

Data in n8n logs	Sensitivity	Retention Status
Recipient email addresses	Personal data (GDPR)	Unacceptable
Email body with download URL + key	Contains decryption key	Absolutely unacceptable
Access tokens	Credential	Unacceptable
Template HTML	Low sensitivity	Acceptable
Workflow execution metadata	Low sensitivity	Acceptable

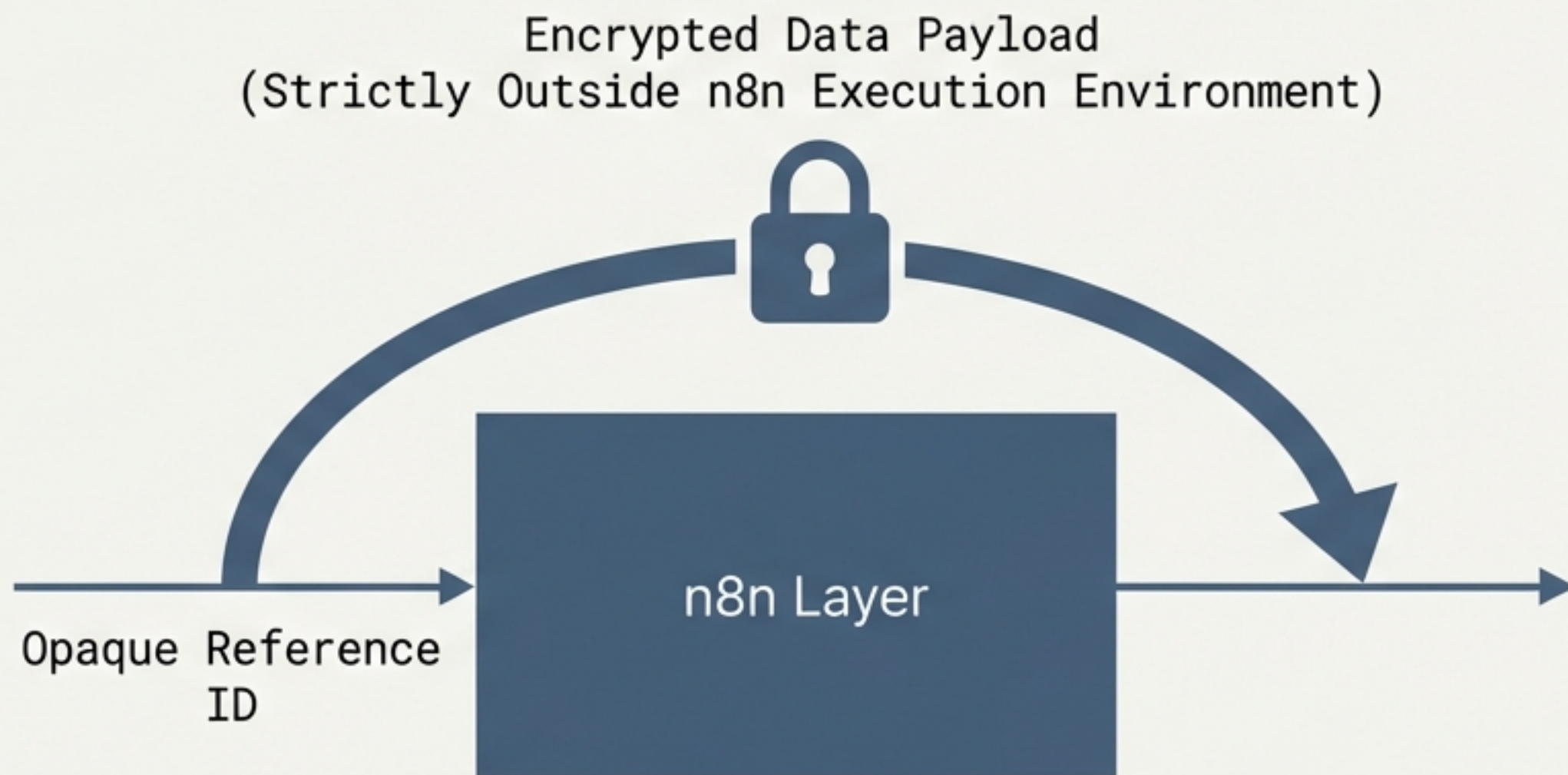
Target State: A full n8n compromise must expose zero customer data and zero decryption keys.

Redefining n8n as an opaque routing layer

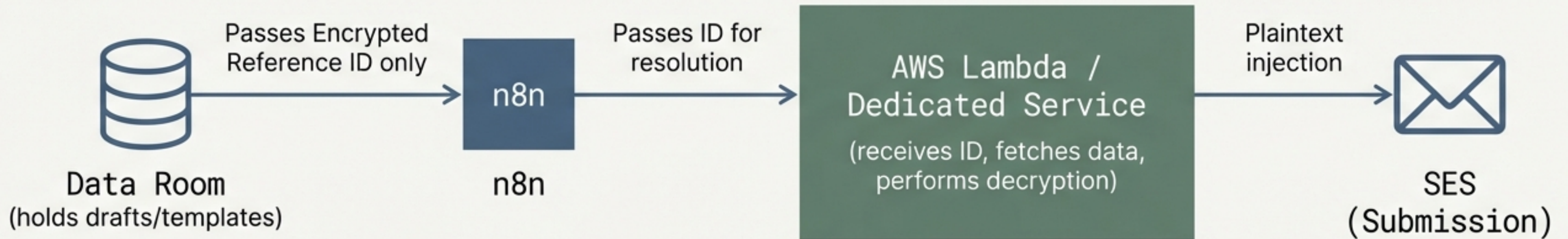
Strategy: Contain, don't replace. Keep n8n for visual triggers, webhook routing, and simple integrations.

Execution: Remove all data processing and data transformation from n8n nodes.

The Rule: Sensitive plaintext data must never pass through n8n's execution context.



Encrypted envelopes decouple orchestration from data access



- Instead of passing plaintext data through n8n nodes, pass encrypted references.
- These references are resolved and decrypted only at the point of use.
- Decryption and SES submission happen in a secure, isolated Lambda function, completely bypassing n8n.

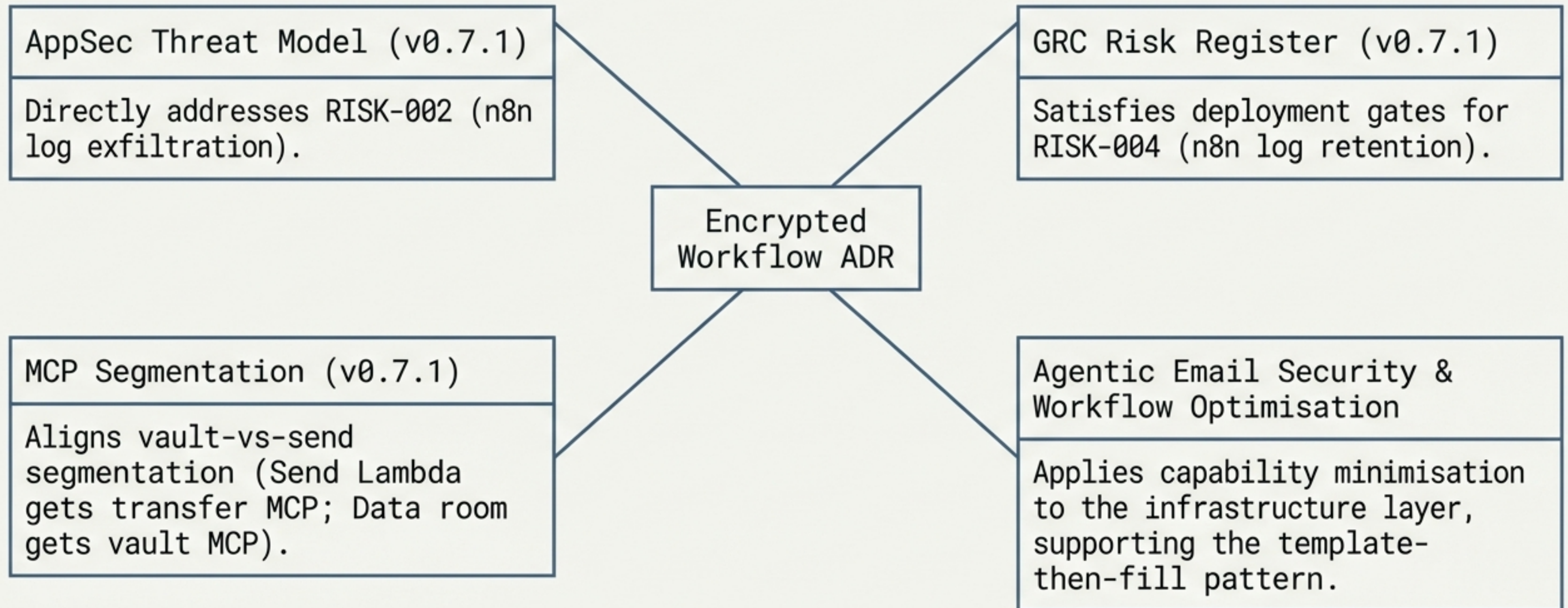
Capability minimisation restricts access at every workflow step

Workflow Step	Permitted Access	Explicitly Blocked
Trigger (webhook/schedule)	✓ Accesses Manifest reference ID	✗ Email content, recipient data
Send step	✓ Scoped read for one recipient's encrypted content	✗ Other recipients, decryption keys for other emails
Status update	✓ Write access to manifest status field	✗ Email content
Notification	✓ Summary stats only (count, success/fail)	✗ Any recipient data

Immediate DevOps mandate for n8n log retention

Execution log retention: Default (indefinite)		7 days maximum
Log full request bodies: Yes (default)		No (log status codes and metadata only)
Log full response bodies: Yes (default)		No
Workflow definition backup: Manual		Automated, version-controlled in git
Credentials storage: Workflow JSON		External AWS Secrets Manager

Alignment with the wider security and risk ecosystem



Phase 1 Acceptance Criteria: Immediate threat mitigation

**Deadline: Before
next outreach batch**

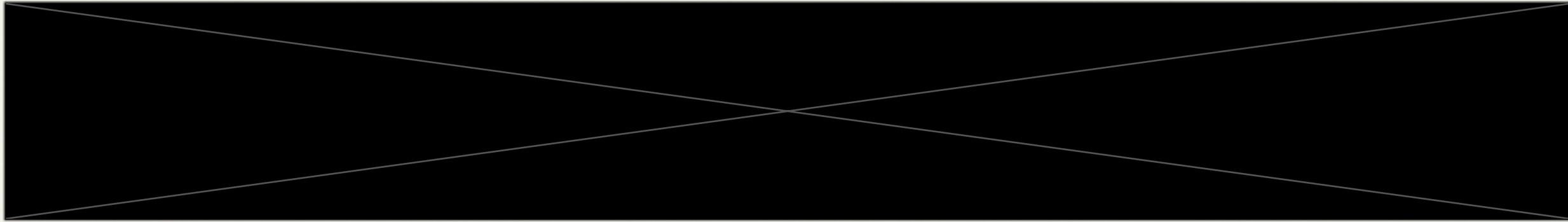
- ☐ 1. Configure n8n execution logs to explicitly reject full request and response bodies.
- ☐ 2. Enforce a hard 7-day maximum on all log retention.
- ☐ 3. Conduct an immediate audit of current n8n logs to identify and aggressively purge any stored decryption keys or plaintext email content.

Phase 2 Acceptance Criteria:

Encrypted envelope rollout

- ☐ 4. Email content passes through n8n strictly as opaque reference IDs.
- ☐ 5. Decryption and SES submission successfully isolated in a Lambda/dedicated service.
- ☐ 6. n8n workflow definitions automatically exported and version-controlled via git.
- ☐ 7. All credentials fully migrated to an external secrets manager.
- ☐ 8. **Final Validation: A full n8n database dump yields zero customer data and zero decryption keys.**

Documentation & Licensing



Reference: v0.7.4__brief__n8n-assessment-and-encrypted-workflow-data



Released under the Creative Commons Attribution 4.0 International licence (CC BY 4.0).
Material may be shared and adapted for any purpose, with appropriate credit.